

Segurtasun konponketenn dokumentazioa

DISEINU EZ SEGURUA

CSRF TOKEN FALTA:

Gure programak ez zuen Anti-CSRF tokena, eta hau beharrezkoa zen hurrengo gauzetarako, saioa hasteko, erregistratzeko, Pokémon bat gehitzeko, Pokémon bat ezabatzeko eta Pokémon bat editzeko. Hau konpontzeko, CSRF token baliozkoa izan behar du. Norbait ekintza horietako bat beste gunetatik token zuzenik gabe egiten saiatzen bada, automatikoki ukatu egingo da. Guk honela implementatu dugu kodean, lehenik eta behin erabiltzaileak lehen azaldutako eskaera bat egiten du, gero sistemak CSRF-a balioztatzen du eta datuak ezabatzen ditu erasorik gertatuko balu datu hauek lapurtu ezin izatek. Gero gure datu base pribatuan erabiltzailearen datuak enkriptatuta gordetzen ditu eta azkenik, erabiltzailearen eskaera betetzen du.*

SEGURTASUN KONFIGURAZIO EZ NAHIKOA

CSP GOIBURUA FALTA:

CSP goiburua ezartzeko hiru pausu jarraitu behar dira. Lehenik eta behin gure html artxiboetan script kodea kendu behar dugu eta kode hau [scripts.js](#) artxiboan idatzi behar ditugu honela HTML artxiboak eta JavaScript artxiboak banatuz. Gero jatorri seguruak eta ez seguruak definitu behar ditugu, default-src 'self' erabiliko dugu. Honek nabigatzaileari esango dio, webgunearen domeinu berdinetik datozen baliabideak kargatzeko aukera baino ez emateko. Azkenik, agindua nabigatzaileara bidali behar da webgunea kargatu baino lehen, honela CSP goiburua konfiguratuz.

Horretarako beharrezko goiburua gehitu daconfig.php klasean, zeina automatikoki beste klase guztiei gehitzen dio, beste klaseetan hasieran config.php jarritz. Konkreteruki 'X-Frame-Options' goiburua erabili da. Zein, alerta kentzeaz gain click-jacking erasoak ekidituko dituz. Horrez gain, XSS babesa emango du.

Kendutako alertak, alerta arriskutsuak izan dira. Beste guztiak, segurtasun aholkuak edo alerta ez hain arriskutsu dira.

